

CYBER SECURITY & ETHICAL HACKING PROGETTO

Esercizio 1: Usare Windows PowerShell

Contesto / Scenario

- PowerShell è un potente strumento di automazione. È sia una console di comando che un linguaggio di scripting. In questo laboratorio, userai la console per eseguire alcuni dei comandi disponibili sia nel prompt dei comandi che in PowerShell. PowerShell ha anche funzioni che possono creare script per automatizzare compiti e lavorare insieme al Sistema Operativo Windows.

Risorse Richieste

- 1 PC Windows con PowerShell installato e accesso a Internet.

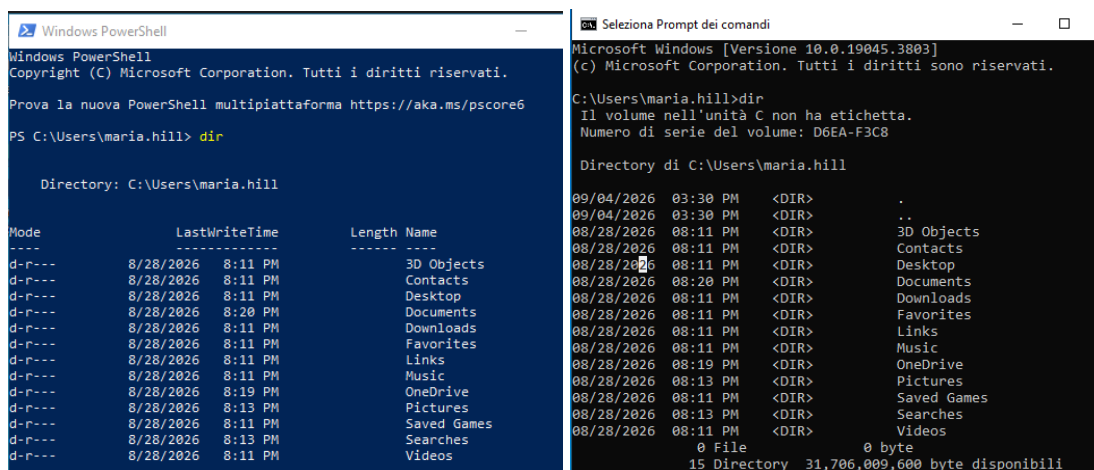
Obiettivi

- L'obiettivo del laboratorio è esplorare alcune delle funzioni di PowerShell.

01. Accedere alla console PowerShell.

02. Esplorare i comandi del Prompt dei comandi e di PowerShell.

Comando dir



```
Windows PowerShell
Copyright (C) Microsoft Corporation. Tutti i diritti riservati.

Prova la nuova PowerShell multiplatforma https://aka.ms/pscore6

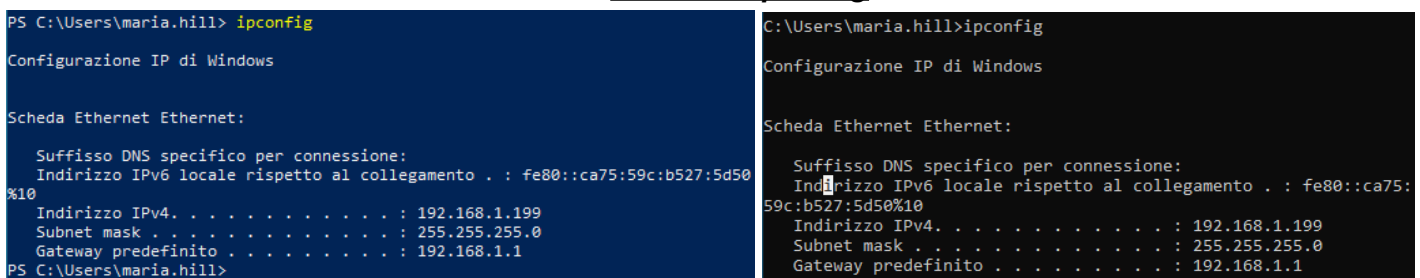
PS C:\Users\maria.hill> dir

Directory: C:\Users\maria.hill

Mode                LastWriteTime         Length Name
----                -
d-r--            8/28/2026   8:11 PM             3D Objects
d-r--            8/28/2026   8:11 PM             Contacts
d-r--            8/28/2026   8:11 PM             Desktop
d-r--            8/28/2026   8:20 PM             Documents
d-r--            8/28/2026   8:11 PM             Downloads
d-r--            8/28/2026   8:11 PM             Favorites
d-r--            8/28/2026   8:11 PM             Links
d-r--            8/28/2026   8:11 PM             Music
d-r--            8/28/2026   8:11 PM             OneDrive
d-r--            8/28/2026   8:13 PM             Pictures
d-r--            8/28/2026   8:11 PM             Saved Games
d-r--            8/28/2026   8:13 PM             Searches
d-r--            8/28/2026   8:11 PM             Videos

09/04/2026   03:30 PM <DIR> .
09/04/2026   03:30 PM <DIR> ..
08/28/2026   08:11 PM <DIR> 3D Objects
08/28/2026   08:11 PM <DIR> Contacts
08/28/2026   08:11 PM <DIR> Desktop
08/28/2026   08:20 PM <DIR> Documents
08/28/2026   08:11 PM <DIR> Downloads
08/28/2026   08:11 PM <DIR> Favorites
08/28/2026   08:11 PM <DIR> Links
08/28/2026   08:11 PM <DIR> Music
08/28/2026   08:19 PM <DIR> OneDrive
08/28/2026   08:13 PM <DIR> Pictures
08/28/2026   08:11 PM <DIR> Saved Games
08/28/2026   08:13 PM <DIR> Searches
08/28/2026   08:11 PM <DIR> Videos
0 File 0 byte
15 Directory 31,706,009,600 byte disponibili
```

Comando ipconfig



```
PS C:\Users\maria.hill> ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::ca75:59c:b527:5d50%10
    Indirizzo IPv4. . . . . : 192.168.1.199
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : 192.168.1.1
PS C:\Users\maria.hill>

C:\Users\maria.hill>ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::ca75:59c:b527:5d50%10
    Indirizzo IPv4. . . . . : 192.168.1.199
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : 192.168.1.1
```

Comando ping

```
PS C:\Users\maria.hill> ping 192.168.1.1
```

```
Esecuzione di Ping 192.168.1.1 con 32 byte di dati:  
Risposta da 192.168.1.199: Host di destinazione non raggiungibile.  
Risposta da 192.168.1.199: Host di destinazione non raggiungibile.  
Risposta da 192.168.1.199: Host di destinazione non raggiungibile.  
Risposta da 192.168.1.199: Host di destinazione non raggiungibile.  
  
Statistiche Ping per 192.168.1.1:  
Pacchetti: Trasmessi = 4, Ricevuti = 4,  
Persi = 0 (0% persi),
```

```
C:\Users\maria.hill>ping 192.168.1.1
```

```
Esecuzione di Ping 192.168.1.1 con 32 byte di dati:  
Risposta da 192.168.1.199: Host di destinazione non raggiungibile  
Risposta da 192.168.1.199: Host di destinazione non raggiungibile  
Risposta da 192.168.1.199: Host di destinazione non raggiungibile  
Risposta da 192.168.1.199: Host di destinazione non raggiungibile  
Risposta da 192.168.1.199: Host di destinazione non raggiungibile  
  
Statistiche Ping per 192.168.1.1:  
Pacchetti: Trasmessi = 4, Ricevuti = 4,
```

Comando cd

```
PS C:\Users\maria.hill> cd  
PS C:\Users\maria.hill>
```

```
C:\Users\maria.hill>cd  
C:\Users\maria.hill
```

03. Esplorare i cmdlet.

- a. I comandi PowerShell, chiamati cmdlet, sono costruiti nella forma di una stringa verbo-nome. Per identificare il comando PowerShell per elencare le sottodirectory e i file in una directory, inserisci `Get-Alias dir` al prompt di PowerShell.

```
PS C:\Users\maria.hill> Get-Alias dir
```

CommandType	Name	Version
-----	----	-----
Alias	dir -> Get-ChildItem	

Qual è il comando PowerShell per `dir`?

*Il cmdlet nativo equivalente a `dir` è **Get-ChildItem**.*

- b. Per informazioni più dettagliate sui cmdlet, esegui una ricerca su internet per **Microsoft powershell cmdlets**.

I **cmdlet** a differenza dei comandi del prompt (CMD), non sono eseguibili autonomi, ma fanno parte di moduli caricati su richiesta e basati sul [framework.NET](https://docs.microsoft.com/en-us/dotnet/framework/).

Struttura e Caratteristiche

- **Formato Verb-Noun:** Ogni cmdlet segue una struttura a coppie composta da un verbo e un sostantivo separati da un trattino (es. **Get-Process**).
- **Verbo:** Identifica l'azione da compiere (es. **Get**, **Set**, **New**, **Remove**).
- **Sostantivo:** Indica la risorsa o l'oggetto su cui agisce il comando (es. **Process**, **Service**, **Item**).
- **Oggetti .NET:** Restituiscono oggetti strutturati anziché semplici flussi di testo, consentendo di concatenare i comandi in una pipeline.

Esempi di Cmdlet Comuni

- **Get-Process:** Recupera l'elenco dei processi in esecuzione.
- **Get-Service:** Mostra lo stato dei servizi di Windows.
- **New-Item:** Crea un nuovo file o una nuova cartella.
- **Set-Location:** Cambia la directory di lavoro corrente (equivalente `cd`).
- **Get-Command:** Elenca tutti i cmdlet e i comandi disponibili nella sessione.

Creare un proprio cmdlet personalizzato attraverso la creazione di una funzione avanzata (chiamata anche "script cmdlet"), che si comporta come un cmdlet nativo.

1. La struttura di base:

```
function New-SalutoPersonalizzato {  
    [CmdletBinding()]  
    param(  
        [Parameter(Mandatory=$true)]  
        [string]$Nome  
    )  
  
    process {  
        Write-Output "Ciao $Nome! Questo è il tuo primo comando  
personalizzato."  
    }  
}
```

2. Perché questa struttura?

- [CmdletBinding()]: è un'istruzione che trasforma una normale funzione in una funzione avanzata, dandole accesso alle funzionalità dei cmdlet nativi (come i parametri -Verbose, -Debug, -WhatIf).
- param(...): Definisce i parametri del comando. Con [Parameter(Mandatory=\$true)] rendi il parametro \$nome obbligatorio.
- process {...}: Contiene il codice che esegue l'azione. è il blocco che elabora i dati, ideale anche se deciderai di passare oggetti tramite pipeline (il carattere |).

3. Bisogna copiare e incollare il testo nella console PowerShell, e premere invio per caricarlo in memoria. Il nuovo comando è: **New-SalutoPersonalizzato -Nome "Marco"**

04. Esplorare il comando netstat usando PowerShell.

comando netstat -h

```
PS C:\Users\maria.hill> netstat -h  
Visualizza le statistiche del protocollo e le connessioni di rete TCP/IP correnti.  
NETSTAT [-a] [-b] [-e] [-f] [-n] [-o] [-p proto] [-r] [-s] [-t] [-x] [-y] [interval]  
  
-a Visualizza tutte le connessioni e le porte di ascolto.  
-b Visualizza l'eseguibile coinvolto nella creazione di ogni connessione o porta di ascolto. In alcuni casi, host di eseguibili noti più componenti indipendenti e in questi casi il sequenza di componenti coinvolti nella creazione della connessione o la porta in ascolto. In questo caso, l'eseguibile il nome è in [] nella parte inferiore, in alto è il componente che ha chiamato, e così via fino al raggiungimento di TCP/IP. Si noti che questa opzione può richiedere molto tempo e avrà esito negativo, a meno che non siano sufficienti autorizzazioni.  
-e visualizza le statistiche Ethernet. È possibile combinare opzione.  
-f Visualizza nomi di dominio completi (FQDN) per stranieri indirizzi.  
-n Visualizza indirizzi e numeri di porta in formato numerico.  
-o Visualizza l'ID del processo proprietario associato a ogni connessione.  
-p proto Mostra le connessioni per il protocollo specificato da proto; proto può essere qualsiasi: TCP, UDP, TCPv6 o UDPv6. Se usato con-s opzione per la visualizzazione delle statistiche per protocollo, Proto può essere qualsiasi: IP, IPv6, ICMP, ICMPv6, TCP, TCPv6, UDP o UDPv6.  
-q Visualizza tutte le connessioni, le porte di ascolto e i binding non in ascolto di porte TCP. Le porte di nonlistening associate possono o meno essere essere associate a una connessione attiva.  
-r Visualizza la tabella di routing.  
-s Visualizza le statistiche per protocollo. Per impostazione predefinita, le statistiche vengono visualizzate per IP, IPv6, ICMP, ICMPv6, TCP, TCPv6, UDP e UDPv6; l'opzione-p può essere utilizzata per specificare un sottoinsieme del valore predefinito.  
-t Visualizza lo stato corrente di offload della connessione.  
-x Visualizza connessioni NetworkDirect, listener e condivisi endpoint.  
-y Visualizza il modello di connessione TCP per tutte le connessioni. Non può essere combinato con le altre opzioni.  
intervallo Rivisualizza le statistiche selezionate, la sospensione dell'intervallo di secondi tra ogni schermo. Premere CTRL+C per interrompere la rivisualizzazione Statistiche. Se viene omissa, netstat stamperà il informazioni di configurazione una volta.
```

comando netstat -r (per visualizzare la tabella di routing con le rotte attive)

```

PS C:\Users\maria.hill> netstat -r
=====
Elenco interfacce
10...08 00 27 6f 19 c7 .....Intel(R) PRO/1000 MT Desktop Adapter
1.....Software Loopback Interface 1
=====

IPv4 Tabella route
=====
Route attive:
Indirizzo rete      Mask      Gateway    Interfaccia Metrica
0.0.0.0             0.0.0.0    192.168.1.1 192.168.1.199 281
127.0.0.0           255.0.0.0    On-link     127.0.0.1 331
127.0.0.1           255.255.255.255 On-link     127.0.0.1 331
127.255.255.255     255.255.255.255 On-link     127.0.0.1 331
192.168.1.0         255.255.255.0  On-link     192.168.1.199 281
192.168.1.199       255.255.255.255 On-link     192.168.1.199 281
192.168.1.255       255.255.255.255 On-link     192.168.1.199 281
224.0.0.0           240.0.0.0    On-link     127.0.0.1 331
224.0.0.0           240.0.0.0    On-link     192.168.1.199 281
255.255.255.255     255.255.255.255 On-link     127.0.0.1 331
255.255.255.255     255.255.255.255 On-link     192.168.1.199 281
=====
Route permanenti:
Indirizzo rete      Mask      Indir. gateway Metrica
0.0.0.0             0.0.0.0    192.168.1.1 Predefinito
=====

IPv6 Tabella route
=====
Route attive:
Interf Metrica Rete Destinazione Gateway
1       331 ::1/128      On-link
10      281 fe80::/64     On-link
10      281 fe80::ca75:59c:b527:5d50/128 On-link
1       331 ff00::/8       On-link
10      281 ff00::/8       On-link
=====
Route permanenti:
Nessuna
PS C:\Users\maria.hill>

```

Qual è il gateway IPv4?

192.168.1.1

Aprire una PowerShell con i privilegi elevati come amministratore. Il comando netstat può anche visualizzare i processi associati alle connessioni TCP attive. Inserisci netstat -abno al prompt.

```

Amministratore: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. Tutti i diritti riservati.

Prova la nuova PowerShell multipiattaforma https://aka.ms/pscore6

PS C:\Windows\system32> netstat -abno

Connessioni attive

Proto  Indirizzo locale      Indirizzo esterno      Stato      PID
TCP    0.0.0.0:135            0.0.0.0:0              LISTENING  860
RpcEptMapper
[svchost.exe]
TCP    0.0.0.0:445            0.0.0.0:0              LISTENING  4
Impossibile ottenere informazioni sulla proprietà
TCP    0.0.0.0:5040           0.0.0.0:0              LISTENING  492
CDPSvc
[svchost.exe]
TCP    0.0.0.0:49664          0.0.0.0:0              LISTENING  656
[lsass.exe]
TCP    0.0.0.0:49665          0.0.0.0:0              LISTENING  500
Impossibile ottenere informazioni sulla proprietà
TCP    0.0.0.0:49666          0.0.0.0:0              LISTENING  748
EventLog
[svchost.exe]
TCP    0.0.0.0:49667          0.0.0.0:0              LISTENING  8
Schedule
[svchost.exe]
TCP    0.0.0.0:49668          0.0.0.0:0              LISTENING  2136
[spoolsv.exe]
TCP    0.0.0.0:49669          0.0.0.0:0              LISTENING  656
[lsass.exe]
TCP    0.0.0.0:49670          0.0.0.0:0              LISTENING  636
Impossibile ottenere informazioni sulla proprietà
TCP    192.168.1.199:139      0.0.0.0:0              LISTENING  4

```

Aprire Gestione attività. Andare sulla scheda dettagli. Mettere in ordine i PID. Selezionare uno dei PID dai risultati di 'netstat -abno'.

Nome	PID	Stato	Nome ute...	CPU	Memoria (...)	Virtualizzazion...
Interrupt sistema	-	In esecuzione	SYSTEM	00	0 K	
Processo di inattività...	0	In esecuzione	SYSTEM	99	8 K	
System	4	In esecuzione	SYSTEM	00	20 K	
svchost.exe	8	In esecuzione	00	20,176 K		
StartMenuExperienc...	64	In esecuzione	maria.hill	00	11,440 K	Disabilitato
Registry	92	In esecuzione	SYSTEM	00	12,728 K	
smss.exe	328	In esecuzione	00	84 K		
svchost.exe	368	In esecuzione	00	780 K		
csrss.exe	428	In esecuzione	00	580 K		
svchost.exe	492	In esecuzione	00	4,816 K		
wininit.exe	500	In esecuzione	00	340 K		
csrss.exe	508	In esecuzione	00	712 K		
svchost.exe	512	In esecuzione	00	4,440 K		
explorer.exe	528	In esecuzione	maria.hill	01	15,628 K	Disabilitato

```

PS C:\Windows\system32> netstat -abno

Connessioni attive

Proto Indirizzo locale Indirizzo esterno Stato PID
TCP 0.0.0.0:135 0.0.0.0:0 LISTENING 860
[RPCSS.exe]
TCP 0.0.0.0:445 0.0.0.0:0 LISTENING 4
[svchost.exe]
Impossibile ottenere informazioni sulla proprietà
TCP 0.0.0.0:5040 0.0.0.0:0 LISTENING 492
[CDPSvc]
[svchost.exe]
TCP 0.0.0.0:49664 0.0.0.0:0 LISTENING 656
[lsass.exe]
TCP 0.0.0.0:49665 0.0.0.0:0 LISTENING 500

```

Proprietà - ntoskrnl	
ntoskrnl	
Tipo di file: Applicazione (.exe)	
Descrizione: NT Kernel & System	
Percorso: C:\Windows\System32	
Dimensioni: 10.3 MB (10,865,112 byte)	
Dimensioni su disco: 10.3 MB (10,866,688 byte)	
Data creazione:	Monday, December 4, 2023, 3:45:46 AM
Ultima modifica:	Monday, December 4, 2023, 3:45:47 AM
Ultimo accesso:	Oggi, September 4, 2026, 24 minutes ago
Attributi: ☐ Solo lettura ☐ Nascosto Avanzate...	

Proprietà - ntoskrnl		
Elenco firme		
Nome firmatario	Algoritmo con cl...	Timestamp
Microsoft Windows	sha256	Saturday, December ...

Proprietà - ntoskrnl	
Nome oggetto: C:\Windows\System32\ntoskrnl.exe	
Utenti e gruppi:	
☒ TUTTI I PACCHETTI APPLICAZIONI ☒ SYSTEM ☒ Administrators (SUPERHACKER\Administrators) ☒ Users (SUPERHACKER\Users) ☒ TrustedInstaller	
Per cambiare le autorizzazioni scegliere Modifica.	
Autorizzazioni per TUTTI I PACCHETTI APPLICAZIONI	
Controllo completo	Consenti
Modifica	
Letture ed esecuzione	✓
Letture	✓
Scrittura	
Autorizzazioni speciali	
Per autorizzazioni speciali o impostazioni avanzate scegliere Avanzate.	

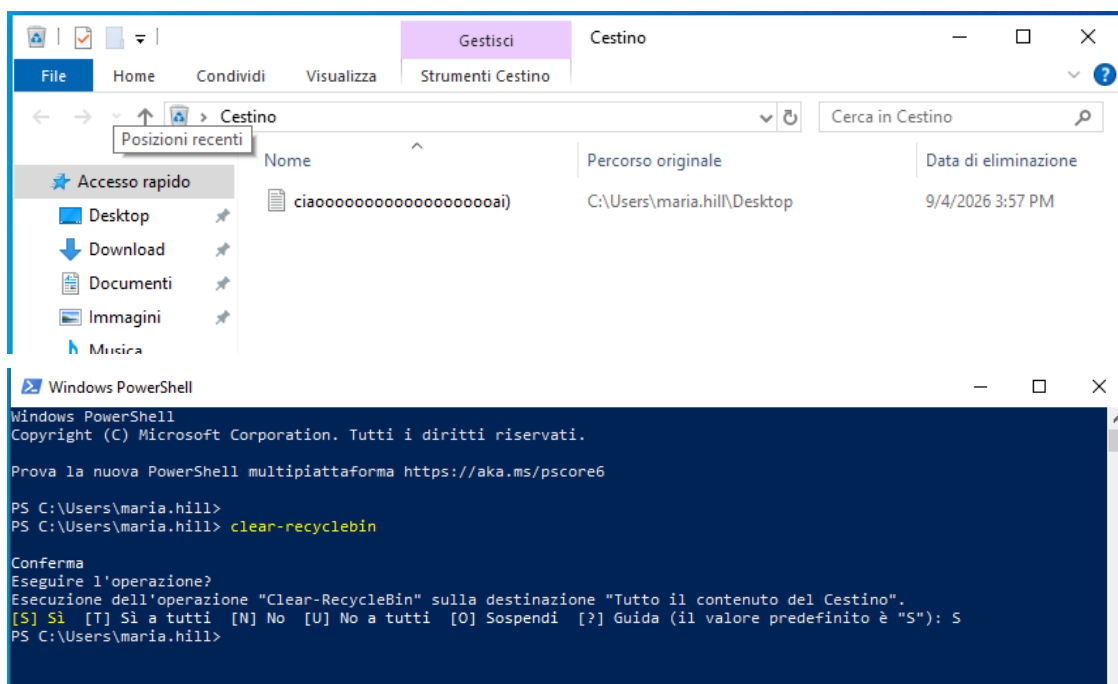
Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra di dialogo Proprietà per il PID selezionato?

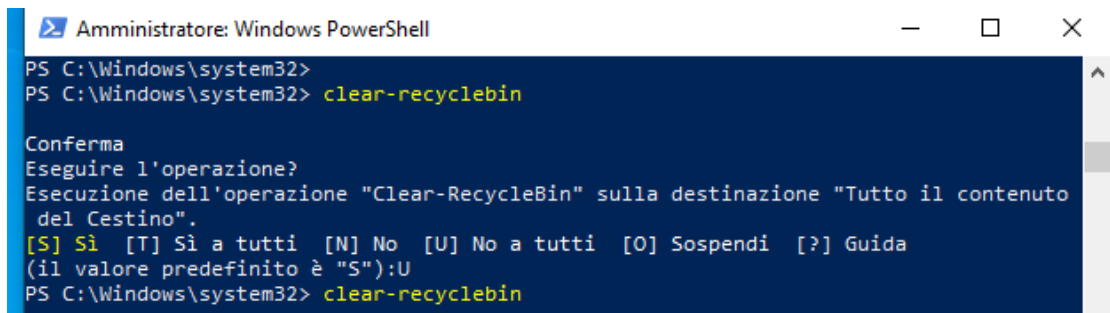
- Proprietà del file:
 - Descrizione del file: NT Kernel & System
 - Nome file originale: ntkrnlmp.exe
 - Versione del file e del prodotto: entrambe corrispondono alla build 10.0.19041.3803
 - Copyright: registrato a nome di Microsoft Corporation. All rights reserved.
 - Lingua: Il file di sistema è configurato originariamente in lingua Inglese.
- Informazioni generali e di sistema:

- Percorso del file: Il file si trova nella directory principale dei file critici di sistema: C:\Windows\System32\ntoskrnl.exe.
- Dimensione del file: il file occupa esattamente 10.3 MB sul disco.
- Integrità e Autenticità (Firme digitali): Il file presenta una firma digitale valida rilasciata direttamente da Microsoft Windows con algoritmo di hash sha256, a conferma che non è stato alterato da terzi.
- Sicurezza e Permessi: L'oggetto appartiene al dominio/computer denominato SUPERHACKER. la gestione del file è blindata dai profili SYSTEM, Administrators e TrustedInstaller.
- Stato PID 4
 - Nome e PID: Il processo è denominato System e ha il PID 4
 - Stato: è attivo e risulta In esecuzione
 - Nome utente: Viene eseguito sotto l'account di sistema con i privilegi massimi (SYSTEM)
 - Impatto sulle risorse: Al momento dello screenshot mostra un utilizzo della CPU pari 00% e un'occupazione di memoria RAM minima pari a 20 K.
 - Attività di rete (da comando netstat): Il PID 4 gestisce attivamente la porta di sistema TCP 445 (utilizzata per la condivisione di file e stampanti in rete tramite protocollo SMB) ed è in stato di ascolto (LISTENING) sull'indirizzo locale 0.0.0.0:445

05. Svuotare il cestino usando PowerShell.

I comandi PowerShell possono semplificare la gestione di una grande rete di computer. Ad esempio, se volessi implementare una nuova soluzione di sicurezza su tutti i server della rete, potresti usare un comando o uno script PowerShell per implementare e verificare che i servizi siano in esecuzione. Puoi anche eseguire comandi PowerShell per semplificare azioni che richiederebbero più passaggi per essere eseguite usando gli strumenti grafici del desktop di Windows.





```
Amministratore: Windows PowerShell
PS C:\Windows\system32>
PS C:\Windows\system32> clear-recyclebin

Conferma
Eseguire l'operazione?
Esecuzione dell'operazione "Clear-RecycleBin" sulla destinazione "Tutto il contenuto
del Cestino".
[Y] Sì [T] Sì a tutti [N] No [U] No a tutti [O] Sospendi [?] Guida
(il valore predefinito è "S"):U
PS C:\Windows\system32> clear-recyclebin
```

Cosa è successo ai file nel Cestino?

I file sono stati eliminati definitivamente, l'operazione ha funzionato nella finestra PowerShell (Utente Normale) e non nella finestra PowerShell Amministratore è legato al modo in cui Windows gestisce i profili. Quando esegui PowerShell come Amministratore, il terminale punta e ha come priorità l'ambiente e il Cestino dell'utente Administrator, il quale risulta già vuoto. Eseguendolo invece dall'account standard, il comando ha ripulito direttamente la tua cartella personale del Cestino (C:\\$Recycle.Bin\S-1-5-21...).

Domanda di Riflessione

PowerShell è stato sviluppato per l'automazione delle attività e la gestione della configurazione. Usando Internet, ricerca comandi che potresti usare per semplificare i tuoi compiti come analista di sicurezza.

- 1. Get-WinEvent:** è il comando fondamentale per analizzare i log. Ad esempio, per trovare tutti i tentativi di accesso riusciti (Event ID 4624) nelle ultime 24 ore:
`Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4624;
StartTime=(Get-Date).AddDays(-1)}`
Invece di aprire il Visualizzatore Eventi, si possono usare query mirate per cercare tracce di attività malevole.
- 2. Get-Process:** permette di estrarre dettagli sui processi attivi ordinandoli, ad esempio, per utilizzo di CPU o verificandone il percorso sul disco.
`Get-Process | Select-Object Name, Id, Path, Company, CPU | Sort-Object CPU -Descending`
Get-CimInstance Win32_Process: Mostra la riga di comando esatta utilizzata per lanciare un processo (essenziale per vedere se un file cmd.exe o powershell.exe ha scaricato script nascosti).
`Get-CimInstance Win32_Process | Select-Object ProcessId, Name, CommandLine`
I malware cercano spesso di nascondersi camuffandosi da processi legittimi di Windows o eseguendo codice non autorizzato.
- 3. Get-NetTCPConnection:** Mostra tutte le connessioni di rete attive filtrandole per stato ed evidenziando il PID che ha originato la connessione.
`Get-NetTCPConnection -State Established | Select-Object LocalAddress, LocalPort,
RemoteAddress, RemotePort, OwningProcess`
Per identificare traffico sospetto verso server di comando e controllo (C2) esterni.
- 4. Get-FileHash:** Calcola l'hash (SHA256, MD5) di un file sospetto trovato sul sistema per poterlo controllare rapidamente su piattaforme di Intelligence come VirusTotal:

Get-FileHash -Path "C:\Percorso\FileSospetto.exe" -Algorithm SHA256

Per verificare l'integrità dei file.

5. **Get-LocalUser** e **Get-LocalGroupMember**: Controllano chi ha i privilegi amministrativi sulla macchina.

Get-LocalGroupMember -Group "Administrators"

Get-ScheduledTask: Elenca le attività pianificate sul computer per verificare se ne esistono di create di recente o con percorsi a cartelle temporanee (come AppData o Temp).

Gli attaccanti creano spesso account locali di backup o attività pianificate per mantenere l'accesso al sistema.

6. **Get-ExecutionPolicy** e **Set-ExecutionPolicy**: Controllano le regole di esecuzione degli script sul sistema, utile per verificare se le protezioni aziendali sono state indebolite.

Get-MpComputerStatus: Permette di verificare lo stato in tempo reale di Microsoft Defender Antivirus e l'aggiornamento delle firme.

Esercizio 2: Studio loc

Bonus 1: Esplorazione di Nmap

Obiettivi:

- Parte 1: Esplorazione di Nmap
- Parte 2: Scansione delle Porte Aperte

Contesto / Scenario:

La scansione delle porte fa solitamente parte di un attacco di ricognizione. Esistono diversi metodi di scansione delle porte utilizzabili. Esploreremo come usare l'utility Nmap. Nmap è una potente utility di rete usata per la scoperta della rete e l'audit di sicurezza.

Risorse richieste:

- Macchina virtuale CyberOps Workstation
- Accesso a Internet

Parte 1: Esplorazione di Nmap

Cos'è Nmap?

è uno strumento open source a riga di comando utilizzato per l'esplorazione delle reti, l'inventario dei dispositivi e il controllo della sicurezza (penetration testing e vulnerability assessment).

Invia pacchetti di rete grezzi (IP, TCP, UDP, ICMP) verso uno o più host per analizzare le risposte e mappare l'infrastruttura.

Funzionalità principali

- Ping Scanning: Individua quali dispositivi IP sono attivi e raggiungibili in una sottorete.
- Port Scanning: Verifica lo stato delle porte di comunicazione (aperte, chiuse o filtrate da firewall)
- Rilevamento dei servizi e versioni (-sV): Identifica quale software risponde su una determinata porta (ad esempio Apache 2.4.41 o OpenSSH 8.2)
- OS Detection (-O): Riconosce il sistema operativo dell'host tramite l'analisi delle risposte allo stack TCP/IP (fingerprinting).

- Automazione con script (NSE - Nmap Scripting Engine): Esegue script in Lua per individuare vulnerabilità note, misconfigurazioni e raccogliere informazioni avanzate.

Comandi tipici

Comando	Descrizione
<code>nmap 192.168.1.1</code>	Scansione rapida delle 1000 porte TCP più comuni
<code>nmap -sS -p 1-65535 192.168.1.50</code>	Scansione stealth (SYN) su tutto il range delle porte
<code>nmap -sV -O 192.168.1.50</code>	Rilevamento di versioni dei servizi e sistema operativo
<code>nmap -A 192.168.1.50</code>	Scansione aggressiva (OS, versioni, traceroute e script base)

Per cosa viene usato Nmap?

Viene usato per gestione operativa dell'infrastruttura e valutazione della sicurezza.

1. Gestione e monitoraggio dell'infrastruttura di rete
 - a. Inventario dei dispositivi: Identificare tutti gli host connessi a una sottorete (computer, server, stampanti, dispositivi IoT) per verificare che non vi siano apparati non autorizzati (Shadow IT).
 - b. Mappatura della topologia: Ricostruire percorsi di rete e hop intermedi (tramite -traceroute) per capire come sono interconnessi i nodi.
 - c. Verifica della disponibilità dei servizi: Controllare da remoto se un demone specifico (come un web server su porta 80/443 o un database su porta 5432) è attivo e risponde correttamente.
 - d. Monitoraggio dei tempi di attività (uptime): Tracciare quali macchine rispondono ai ping sweep periodici.
2. Cybersecurity e Penetration Testing
 - a. Reconnaissance (raccolta informazioni): Nella fase iniziale di un test di penetrazione, Nmap serve a individuare la superficie di attacco esposta verso l'esterno o all'interno della LAN.
 - b. Rilevamento di porte aperte non necessarie: Individuare servizi dimenticati, mal configurati o esposti per errore (es. Porte Telnet, RDP o SMB aperte verso Internet).
 - c. Audit delle versioni del software: Con l'opzione -sV, elenca le versioni esatte dei servizi attivi, permettendo di verificare se sono affetti da CVE (vulnerabilità e falle di sicurezza note).
 - d. Test dei firewall e delle ACL: Verificare se le regole di filtraggio del traffico (firewall hardware, iptables, WAF) bloccano effettivamente le porte desiderate o se esistono regole permissive anomale.

- e. Vulnerability Assessment automatizzato (NSE): Tramite la libreria di script integrata. Nmap può verificare direttamente la presenza di vulnerabilità critiche o misconfigurazioni (credenziali di default nei servizi di gestione).

```
Applications: Terminal - analyst@sec0... Terminal - analyst@sec0ps~
File Edit View Terminal Tabs Help
NMAP(1) Nmap Reference Guide NMAP(1)
NAME
nmap - Network exploration tool and security / port scanner
SYNOPSIS
nmap [Scan Type...] [Options] (target specification)
DESCRIPTION
Nmap ("Network Mapper") is an open source tool for network exploration and security auditing. It was designed to rapidly scan large networks, although it works fine against single hosts. Nmap uses raw IP packets in novel ways to determine what hosts are available on the network, what services (application name and version) those hosts are offering, what operating systems (and OS versions) they are running, what type of packet filters/firewalls are in use, and dozens of other characteristics. While Nmap is commonly used for security audits, many systems and network administrators find it useful for routine tasks such as network inventory, managing service upgrade schedules, and monitoring host or service uptime.
The output from Nmap is a list of scanned targets, with supplemental information on each depending on the options used. Key among that information is the "interesting ports table". That table lists the port number and protocol, service name, and state. The state is either open, filtered, closed, or unfiltered. Open means that an application on the target machine is listening for connections/packets on that port. Filtered means that a firewall, filter, or other network obstacle is blocking the port so that Nmap cannot tell whether it is open or closed. Closed ports have no application listening on them, though they could open up at any time. Ports are classified as unfiltered when they are responsive to Nmap's probes, but Nmap cannot determine whether they are open or closed. Nmap reports the state combinations open/filtered and closed/filtered when it cannot determine which of the two states describe a port. The port table may also include software version details when version detection has been requested. When an IP protocol scan is requested (-s0), Nmap provides information on supported IP protocols rather than listening ports.
In addition to the interesting ports table, Nmap can provide further information on targets, including reverse DNS names, operating system guesses, device types, and MAC addresses.
A typical Nmap scan is shown in Example 1. The only Nmap arguments used in this example are -A, to enable OS and version detection, script scanning, and traceroute; -T4 for faster execution; and then the hostname.
Example 1. A representative Nmap scan
# nmap -A -T4 scanme.nmap.org
Nmap scan report for scanme.nmap.org (74.207.244.221)
Host is up (0.029s latency).
rDNS record for 74.207.244.221: 1186-221.members.linode.com
Not shown: 995 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 5.3p1 Debian 3ubuntu7 (protocol 2.0)
|_ ssh-hostkey: 1024 8d:60:f1:7c:ca:b7:3d:0a:d6:67:54:9d:09:d9:b9:dd (DSA)
|_ 2048 79:f8:09:ac:d4:e2:32:42:10:49:d3:bd:20:82:85:ec (RSA)
80/tcp    open  http      Apache httpd 2.2.14 ((Ubuntu))
Manual page nmap(1) line 1 (press h for help or q to quit)
```

```
Applications: Terminal - analyst@sec0... Terminal - analyst@sec0ps~
File Edit View Terminal Tabs Help
EXAMPLES:
SEE THE MAN PAGE (https://nmap.org/book/man.html) FOR MORE OPTIONS AND EXAMPLES
which the first numbits are the same as for the reference IP or hostname given. For example, 192.168.10.0/24 would scan the 256 hosts between 192.168.10.0 (binary: 11000000 10101000 00001010 00000000)
CIDR notation is short but not always flexible enough. For example, you might want to scan 192.168.0.0/16 but skip any IPs ending with .0 or .255 because they may be used as subnet network and broadcast addresses. Nmap supports this through octet range addressing. Rather than specify a normal IP address, you can specify a comma-separated list of numbers or ranges for each octet. For example,
Reads target specifications from inputfilename. Passing a huge list of hosts is often awkward on the command line, yet it is a common desire. For example, your DHCP server might export a list of resolution on the hosts to learn their names. It is often surprising how much useful information simple hostnames give out. For example, fw.chi is the name of one company's Chicago firewall.
be specified as a parameter. The syntax is the same as for the -p except that port type specifiers like T: are not allowed. Examples are -PS22 and -PS22-25.00.113.1056.35000. Note that there can be
The primary advantage of this scan type is that it bypasses firewalls and filters that only screen TCP. For example, I once owned a Linksys BEFW1154 wireless broadband router. The external interface can be specified as a parameter. The syntax is the same as for the -p except that port type specifiers like S: are not allowed. Examples are -PY22 and -PY22.80.179.5060. Note that there can be no
These states are not intrinsic properties of the port itself, but describe how Nmap sees them. For example, an Nmap scan from the same network as the target may show port 135/tcp as open, while a scan at scan, many hosts rate limit ICMP port unreachable messages by default. Linux and Solaris are particularly strict about this. For example, the Linux 2.4.20 kernel limits destination unreachable
example, --scanflags URGACKPSHSTSYNFIN sets everything, though it's not very useful for scanning. The order these are specified in is irrelevant.
In addition to specifying the desired flags, you can specify a TCP scan type (such as -sA or -sF). That base type tells Nmap how to interpret responses. For example, a SYN scan considers no-response
qualifier lasts until you specify another qualifier. For example, the argument -p U:53,111,137,T:21-25.00.139.8080 would scan UDP ports 53, 111, and 137, as well as the listed TCP ports. Note that to
can also be specified by name according to what the port is referred to in the nmap-services. You can even use the wildcards * and ? with the names. For example, to scan FTP and all ports whose
```

```
Example 1. A representative Nmap scan
# nmap -A -T4 scanme.nmap.org
Nmap scan report for scanme.nmap.org (74.207.244.221)
Host is up (0.029s latency).
rDNS record for 74.207.244.221: 1186-221.members.linode.com
Not shown: 995 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 5.3p1 Debian 3ubuntu7 (protocol 2.0)
|_ ssh-hostkey: 1024 8d:60:f1:7c:ca:b7:3d:0a:d6:67:54:9d:09:d9:b9:dd (DSA)
|_ 2048 79:f8:09:ac:d4:e2:32:42:10:49:d3:bd:20:82:85:ec (RSA)
80/tcp    open  http      Apache httpd 2.2.14 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
646/tcp   filtered ldp
1728/tcp  filtered H.323/Q.931
9929/tcp  open  nping-echo Nping echo
Device type: general purpose
Running: Linux 2.6.39
OS CPE: cpe:/o:linux:linux_kernel:2.6.39
OS details: Linux 2.6.39
Network Distance: 11 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:kernel
TRACEROUTE (using port 53/tcp)
HOP RTT ADDRESS
[Cut first 10 hops for brevity]
11 17.65 ms 1186-221.members.linode.com (74.207.244.221)
Nmap done: 1 IP address (1 host up) scanned in 14.40 seconds
The newest version of Nmap can be obtained from https://nmap.org. The newest version of this man page is available at https://nmap.org/book/man.html. It is also included as a chapter of Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning (see https://nmap.org/book/).
```

Cosa fa l'opzione -A?

Cosa fa l'opzione -T4?

Opzione -A (Aggressive scan options)

Abilita un pacchetto di funzionalità avanzate di rilevamento in un unico flag:

- OS Detection (-O): Riconosce il sistema operativo tramite fingerprinting TCP/IP (nell'output: OS details: Linux 2.6.39).
- Version Detection (-sV): Determina le versioni precise dei servizi in ascolto sulle porte aperte (es. OpenSSH 5.3p1, Apache httpd 2.2.14).
- Script Scanning (-sC): Esegue la suite di script Lua di default (NSE) per raccogliere ulteriori dettagli (es. chiavi host SSH, http-title).
- Traceroute (--traceroute): Traccia il percorso di rete e il numero di hop necessari a raggiungere l'host (nella parte inferiore: TRACEROUTE (using port 53/tcp)).

Opzione -T4 (Timing template: Aggressive)

Regola la velocità e i timeout della scansione per renderla più rapida:

- Nmap prevede 6 profili temporali, da T0 (paranoid, estremamente lento per eludere IDS) a T5 (insane, velocissimo ma rischioso di perdita pacchetti).
- T4 ottimizza i tempi di attesa per reti moderne, stabili e veloci: imposta timeout più brevi per le risposte (max RTT timeout a 1.25 secondi) e velocizza l'invio dei pacchetti, riducendo significativamente la durata complessiva del test senza saturare la banda.

Parte 2: Scansione delle Porte Aperte

Passo 1: Scansiona il tuo localhost

```
[analyst@secOps ~]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-09-04 11:22 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000039s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0          0 Mar 26  2018 ftp_test
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 127.0.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.92 seconds
```

Quali porte e servizi sono aperti?

- Porta 21/tcp
 - Servizio: ftp
 - Versione: vsftpd 2.0.8 or later (lo script di stato identifica nello specifico vsFTPD 3.0.5)
 - Dettaglio rilevato: Permette l'accesso anonimo (Anonymous FTP login allowed).

- Porta 22/tcp
 - Servizio: ssh
 - Versione: OpenSSH 10.0 (protocol 2.0)

Passo 2: Scansione la tua rete

Attenzione: Prima di usare Nmap su qualsiasi rete, ottieni il permesso dei proprietari della rete prima di procedere.

```
nmap done: 1 IP address (1 host up) scanned in 0.112 seconds
[analyst@secOps ~]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 192.168.5.173/24 metric 1024 brd 192.168.5.255 scope global dynamic enp0s3
        valid_lft 14659sec preferred_lft 14659sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
```

Indirizzo IP e subnet mask di questo host

A quale rete appartiene la tua VM?

192.168.5.0/24

Per localizzare altri host su questa LAN, inserisci `nmap -A -T4 indirizzo_rete/prefisso`

```

[analyst@secOps ~]$ nmap -A -T4 192.168.5.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-09-09 06:13 -0400
Nmap scan report for 192.168.5.1
Host is up (0.025s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
9000/tcp  open  cslistener?

Nmap scan report for 192.168.5.6
Host is up (0.017s latency).
All 1000 scanned ports on 192.168.5.6 are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

Nmap scan report for 192.168.5.157
Host is up (0.023s latency).
All 1000 scanned ports on 192.168.5.157 are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

Nmap scan report for 192.168.5.172
Host is up (0.020s latency).
All 1000 scanned ports on 192.168.5.172 are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

Nmap scan report for 192.168.5.173
Host is up (0.00060s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0              0 Mar 26  2018 ftp_test
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.5.173
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|
|_vsFTPd 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Nmap scan report for 192.168.5.213
Host is up (0.037s latency).
All 1000 scanned ports on 192.168.5.213 are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (6 hosts up) scanned in 101.20 seconds

```

Quanti host sono attivi?

- 192.168.5.1
- 192.168.5.6

- 192.168.5.157
- 192.168.5.172
- 192.168.5.173

Dai risultati di Nmap, elenca gli indirizzi IP degli host che si trovano sulla stessa LAN della tua VM. Elenca alcuni dei servizi disponibili sugli host rilevati.

Passo 3: Scansiona un server remoto

Apri un browser web e naviga su scanme.nmap.org . Leggi il messaggio pubblicato. Qual'è lo scopo di questo sito?

```
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-09-05 13:08 -0400
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.23s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 closed tcp ports (conn-refused)
PORT      STATE      SERVICE      VERSION
22/tcp    open      ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|   2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|   256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_  256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    filtered  http
9929/tcp  open      nping-echo   Nping echo
31337/tcp open      Elite?
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 111.33 seconds
```

Quali porte e servizi sono aperti?

- 22/tcp: ssh - Versione: OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (protocollo 2.0)
- 9929/tcp: nping-echo - Versione: Nping echo
- 31337/tcp: Elite?

Quali porte e servizi sono filtrati?

- 80/tcp: servizio http (stato: filtered)

Qual è l'indirizzo IP del server?

- IPv4: 45.33.32.156 (è presente anche l'indirizzo IPv6 2600:3c01::f03c:91ff:fe18:bb2f, indicato ma non scansionato)

Qual è il sistema operativo?

- Linux (più nello specifico, la distribuzione indicata dal banner SSH è Ubuntu Linux; CPE: cpe:/o:linux:linux_kernel)

Domanda di Riflessione

Nmap è uno strumento potente per l'esplorazione e la gestione della rete.

Come può Nmap aiutare con la sicurezza della rete?

- Riduzione della superficie d'attacco: Consente agli amministratori di individuare porte aperte o servizi superflui dimenticati (come server web di test o vecchi demoni Telnet/FTP) per chiuderli o disattivarli.
- Audit e gestione delle vulnerabilità: Tramite il rilevamento delle versioni (-sV) e gli script NSE, i difensori possono verificare rapidamente quali macchine eseguono software obsoleto affetto da falle note (CVE) prima che vengano sfruttate.
- Verifica dell'efficacia di firewall e ACL: Permette di convalidare le regole perimetrali controllando se le porte che dovrebbero essere protette risultano effettivamente filtered o se filtraggi errati espongono risorse critiche.
- Contrasto allo Shadow IT: Scansionando regolarmente i segmenti di rete interni, aiuta a individuare apparati non autorizzati collegati dai dipendenti (router personali, NAS, schede IoT).

Come può Nmap essere usato da un attore malevole come strumento nefasto?

- Reconnaissance (Ricognizione preliminare): È la prima fase della kill chain. L'attaccante mappa la topologia di rete del bersaglio, identifica gli indirizzi IP attivi e crea un inventario dei punti di ingresso sfruttabili.
- Targeting mirato dei software: Individuando le versioni precise dei servizi (es. OpenSSH 6.6.1 o vsftpd datato), il cybercriminale non deve procedere alla cieca, ma cerca direttamente exploit pubblici o zero-day adatti a quella specifica release.
- Evitamento del rilevamento (Evasion): Funzionalità avanzate di Nmap (frammentazione dei pacchetti -f, scansioni lente -T0/-T1, spoofing di decoy -D o scansioni SYN "stealth" -sS) possono essere usate per non far scattare gli allarmi dei sistemi IDS/IPS e non lasciare tracce evidenti nei log.
- Scansione automatizzata di debolezze con NSE: Gli script integrati possono essere impiegati in modo malevolo per testare credenziali di default (brute force su SSH/FTP/database) o identificare falle critiche senza configurare strumenti offensivi dedicati.

Bonus 2: Attacco a un database MySQL

Obiettivi

In questo laboratorio, visualizzerai un file PCAP di un attacco precedente contro un database SQL.

- Parte 1 Aprire Wireshark e caricare il file PCAP.
- Parte 2 Visualizzare l'attacco di SQL Injection.
- Parte 3 L'attacco di SQL Injection continua...
- Parte 4 L'attacco di SQL Injection fornisce informazioni di sistema.
- Parte 5 L'attacco di SQL Injection e le informazioni sulle tabelle
- Parte 6 L'attacco di SQL Injection si conclude.

Contesto / Scenario

Gli attacchi di SQL injection consentono agli hacker malintenzionati di digitare istruzioni SQL in un sito web e ricevere una risposta dal database. Ciò permette agli aggressori di manomettere i dati

correnti nel database, falsificare identità e compiere varie azioni dannose. È stato creato un file PCAP per consentirti di visualizzare un attacco precedente contro un database SQL. In questo laboratorio, visualizzerai gli attacchi al database SQL e risponderai alle domande.

Risorse Richieste

- Macchina virtuale CyberOps Workstation

Quali sono i due indirizzi IP coinvolti in questo attacco di SQL injection in base alle informazioni visualizzate?

No.	Time	Source	Destination	Protocol	Length	Info
6	0.005700	10.0.2.15	10.0.2.4	HTTP	430	HTTP/1.1 302 Found
7	0.005700	10.0.2.4	10.0.2.15	TCP	66	35614-80 [ACK] Seq=589 Ack=365 Win=30336 Len=0 TSval=45840 TSecr=90
8	0.014383	10.0.2.4	10.0.2.15	HTTP	496	GET /dvwa/index.php HTTP/1.1
9	0.015485	10.0.2.15	10.0.2.4	HTTP	3107	HTTP/1.1 200 OK (text/html)
10	0.015485	10.0.2.4	10.0.2.15	TCP	66	35614-80 [ACK] Seq=1019 Ack=3406 Win=36480 Len=0 TSval=45843 TSecr=90
11	0.068625	10.0.2.4	10.0.2.15	HTTP	429	GET /dvwa/dvwa/css/main.css HTTP/1.1
12	0.070400	10.0.2.15	10.0.2.4	HTTP	1511	HTTP/1.1 200 OK (text/css)
13	174.254430	10.0.2.4	10.0.2.15	HTTP	536	GET /dvwa/vulnerabilities/sqli/?id=1%3D1&Submit=Submit HTTP/1.1
14	174.254581	10.0.2.15	10.0.2.4	TCP	66	80-35638 [ACK] Seq=1 Ack=471 Win=235 Len=0 TSval=82101 TSecr=90
15	174.257989	10.0.2.15	10.0.2.4	HTTP	1861	HTTP/1.1 200 OK (text/html)
16	220.490531	10.0.2.4	10.0.2.15	HTTP	577	GET /dvwa/vulnerabilities/sqli/?id=1%27+or+%270%27%3D%270+&Submit=Submit HTTP/1.1
17	220.490637	10.0.2.15	10.0.2.4	TCP	66	80-35640 [ACK] Seq=1 Ack=512 Win=235 Len=0 TSval=93660 TSecr=10
18	220.493085	10.0.2.15	10.0.2.4	HTTP	1918	HTTP/1.1 200 OK (text/html)
19	277.727722	10.0.2.4	10.0.2.15	HTTP	630	GET /dvwa/vulnerabilities/sqli/?id=1%27+or+1%3D1+union+select+ HTTP/1.1
20	277.727871	10.0.2.15	10.0.2.4	TCP	66	80-35642 [ACK] Seq=1 Ack=565 Win=236 Len=0 TSval=107970 TSecr=10
21	277.732200	10.0.2.15	10.0.2.4	HTTP	1955	HTTP/1.1 200 OK (text/html)
22	313.710129	10.0.2.4	10.0.2.15	HTTP	659	GET /dvwa/vulnerabilities/sqli/?id=1%27+or+1%3D1+union+select+ HTTP/1.1
23	313.710277	10.0.2.15	10.0.2.4	TCP	66	80-35644 [ACK] Seq=1 Ack=594 Win=236 Len=0 TSval=116966 TSecr=10
24	313.712414	10.0.2.15	10.0.2.4	HTTP	1954	HTTP/1.1 200 OK (text/html)
25	383.277032	10.0.2.4	10.0.2.15	HTTP	680	GET /dvwa/vulnerabilities/sqli/?id=1%27+or+1%3D1+union+select+ HTTP/1.1
26	383.277811	10.0.2.15	10.0.2.4	TCP	66	80-35666 [ACK] Seq=1 Ack=615 Win=236 Len=0 TSval=134358 TSecr=10
27	383.284289	10.0.2.15	10.0.2.4	HTTP	4068	HTTP/1.1 200 OK (text/html)
28	441.804070	10.0.2.4	10.0.2.15	HTTP	685	GET /dvwa/vulnerabilities/sqli/?id=1%27+or+1%3D1+union+select+ HTTP/1.1
29	441.804427	10.0.2.15	10.0.2.4	TCP	66	80-35668 [ACK] Seq=1 Ack=620 Win=236 Len=0 TSval=148990 TSecr=10
30	441.807206	10.0.2.15	10.0.2.4	HTTP	2091	HTTP/1.1 200 OK (text/html)

I due indirizzi IP coinvolti sono:

- 10.0.2.4 — L'attaccante / client (sorgente che invia le richieste HTTP GET contenenti i payload SQLi verso /dvwa/vulnerabilities/sqli/, ad esempio con union+select...).
- 10.0.2.15 — Il server web / bersaglio (destinazione delle richieste che risponde con codice HTTP/1.1 200 OK).

The screenshot shows the Wireshark network protocol analyzer. The packet list on the left shows packet 13 selected, which is an HTTP 200 OK response. The packet details pane on the right shows the structure of the HTTP response, including the status bar and content type. The 'Apply as Filter' menu is open, showing various filtering options. The 'HTTP Stream' option is highlighted with a red rectangle, indicating it is the selected filter.

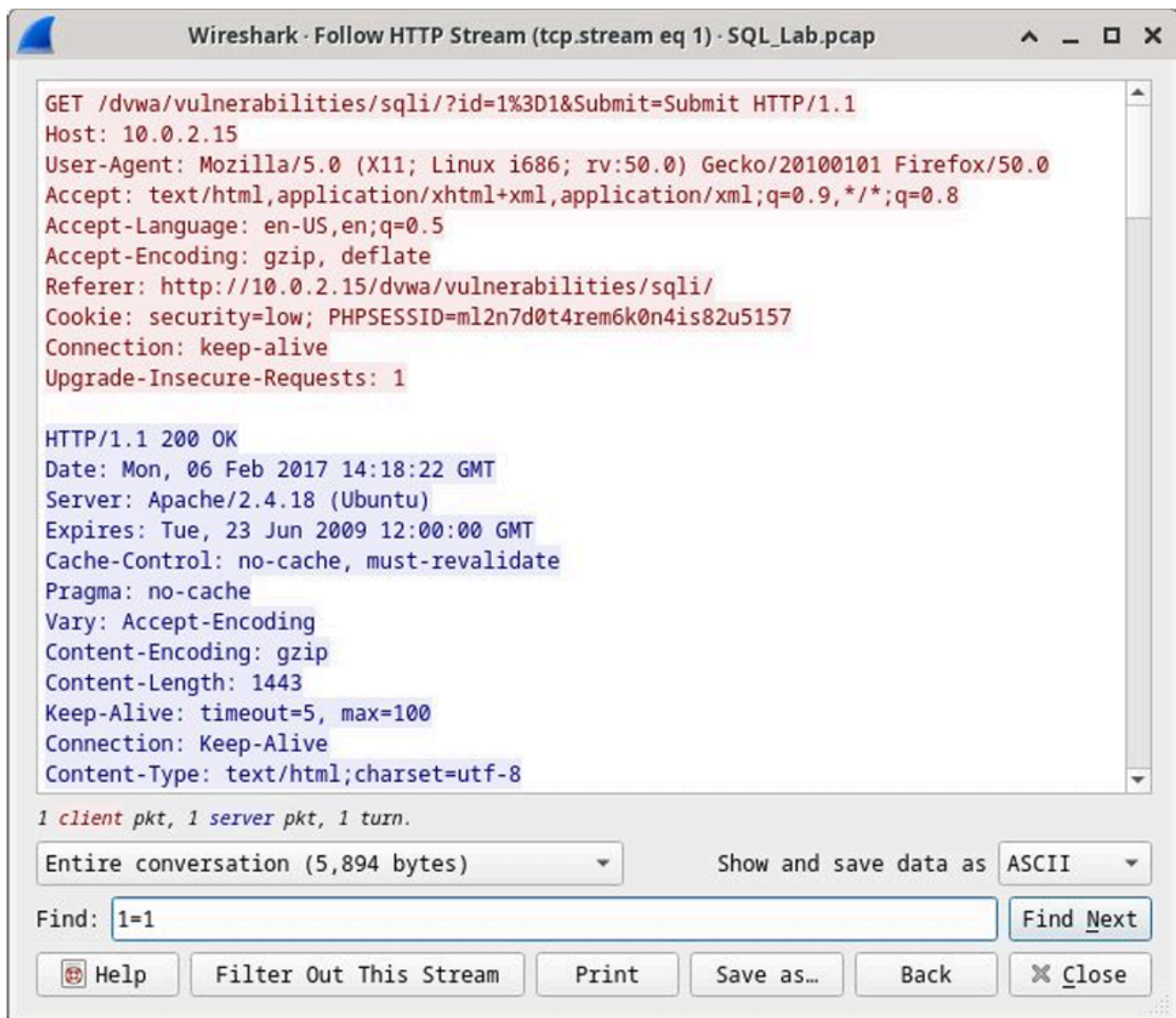
No.	Time	Source	Destination	Protocol	Length	Info
12	0.070400	10.0.2.15	10.0.2.4	HTTP	1511	HTTP/1.1 200 OK (text/css)
13	174.254430	10.0.2.4	10.0.2.15	HTTP	536	200 OK (text/html) dvwa/vulnerabilities/sqli/?id=1%3D1&Submit=1
14	174.254581	10.0.2.15	10.0.2.4	TCP	60	35638 [ACK] Seq=1 Ack=471 Win=235 Len=0
15	174.257989	10.0.2.15	10.0.2.4	TCP	60	1.1 200 OK (text/html)
16	220.490531	10.0.2.4	10.0.2.15	HTTP	536	200 OK (text/html) dvwa/vulnerabilities/sqli/?id=1%27+or+%27=1
17	220.490637	10.0.2.15	10.0.2.4	TCP	60	35640 [ACK] Seq=1 Ack=512 Win=235 Len=0
18	220.493085	10.0.2.15	10.0.2.4	TCP	60	1.1 200 OK (text/html)
19	277.727722	10.0.2.4	10.0.2.15	HTTP	536	200 OK (text/html) dvwa/vulnerabilities/sqli/?id=1%27+or+%27=1
20	277.727871	10.0.2.15	10.0.2.4	TCP	60	35642 [ACK] Seq=1 Ack=565 Win=236 Len=0
21	277.732200	10.0.2.15	10.0.2.4	TCP	60	1.1 200 OK (text/html)

The 'Apply as Filter' menu is open, showing the following options:

- Mark/Unmark Packet (Ctrl+M)
- Ignore/Unignore Packet (Ctrl+D)
- Set/Unset Time Reference (Ctrl+T)
- Time Shift... (Ctrl+Shift+T)
- Packet Comment... (Ctrl+Alt+C)
- Edit Resolved Name
- Apply as Filter
- Prepare as Filter
- Conversation Filter
- Colorize Conversation
- SCTP
- Follow
- Copy
- Protocol Preferences
- Decode As...
- Show Packet in New Window

The 'Follow' option is selected, and the 'HTTP Stream' option is highlighted with a red rectangle.

Stream	Filter
TCP Stream	Ctrl+Alt+Shift+T
UDP Stream	Ctrl+Alt+Shift+U
TLS Stream	Ctrl+Alt+Shift+S
HTTP Stream	Ctrl+Alt+Shift+H
HTTP/2 Stream	
QUIC Stream	



Wireshark · Follow HTTP Stream (tcp.stream eq 1) · SQL_Lab.pcap

```
<input type="submit" name="Submit" value="Submit">
</p>
</form>
<pre>ID: 1=1<br />First name: admin<br />Surname: admin</pre>
</div>
<h2>More Information</h2>
<ul>
<li><a href="http://www.securiteam.com/securityreviews/SDP0N1P76E.html" target="_blank">http://www.securiteam.com/securityreviews/

1 client pkt, 1 server pkt, 1 turn.



Entire conversation (5,894 bytes) Show and save data as ASCII



Find: 1=1 Find Next



Help Filter Out This Stream Print Save as... Back Close

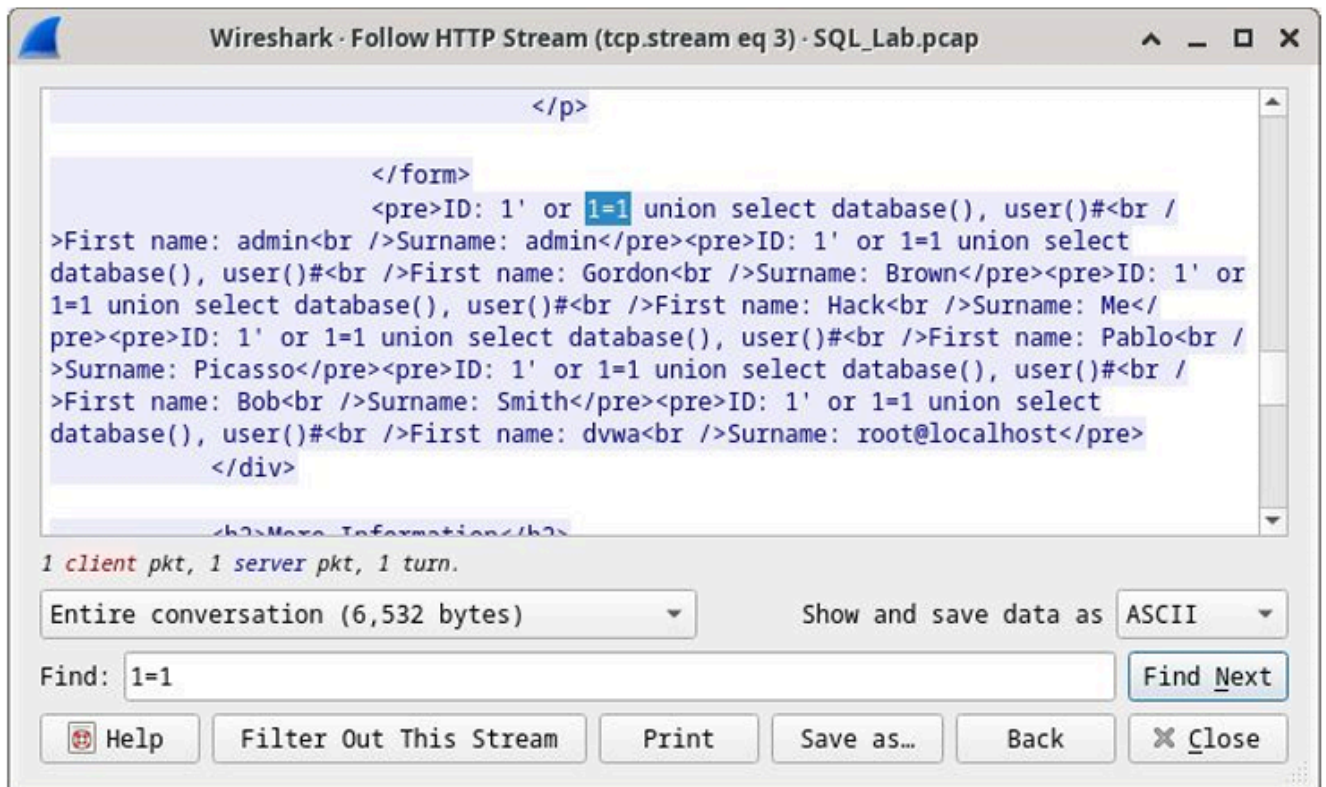

```

SQL_Lab.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tcp.stream eq 1

No.	Time	Source	Destination	Protocol	Length	Info
13	174.254430	10.0.2.4	10.0.2.15	HTTP	536	GET /dwa/vulnerabili
14	174.254581	10.0.2.15	10.0.2.4	TCP	66	80 → 35638 [ACK] Seq=
15	174.257989	10.0.2.15	10.0.2.4	HTTP	1861	HTTP/1.1 200 OK (tex

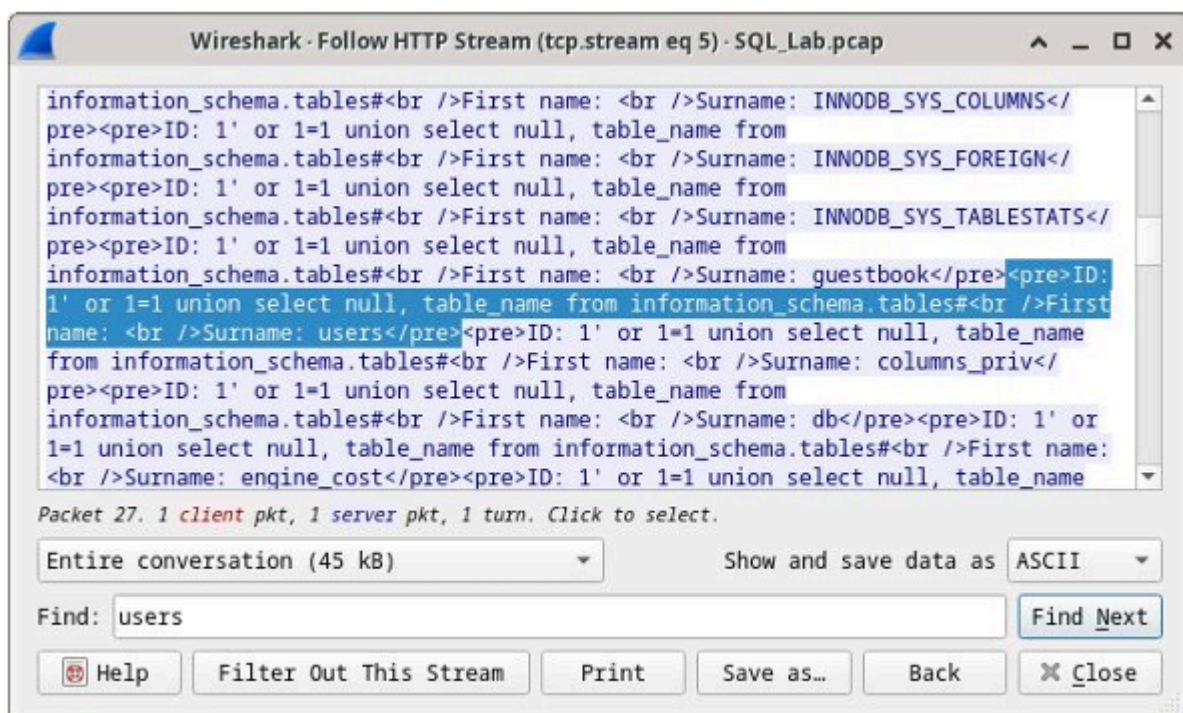


Qual'è la versione?

Apache/2.4.18 (Ubuntu)

Altri dettagli di versione visibili nello stesso flusso:

- Versione HTTP: HTTP/1.1
- Versione Browser (User-Agent): Firefox/50.0 (su Linux i686)





Quale utente ha l'hash della password di 8d3533d75ae2c3966d7e0d4fcc69216b?

L'utente è 1337.

Dal payload SQL injection (union select user, password from users#), il campo user viene stampato su First name e il campo password su Surname:

- First name (user): 1337
- Surname (password hash): 8d3533d75ae2c3966d7e0d4fcc69216b

Qual'è la password in chiaro?

```
import hashlib
```

```
hash_da_trovare = "8d3533d75ae2c3966d7e0d4fcc69216b"
```

```
percorso_lista = "/usr/share/wordlists/rockyou.txt"
```

try:

```
with open(percorso_lista, "r", encoding="latin-1") as file:
```

```
    for riga in file:
```

```
        parola = riga.strip()
```

```
        hash_calcolato = hashlib.md5(parola.encode('utf-8')).hexdigest()
```

```
        if hash_calcolato == hash_da_trovare:
```

```
            print(f" CORRISPONDENZA TROVATA!")
```

```
            print(f"L'hash corrisponde alla parola: {parola}")
```

```
            break
```

```
        else: print("Fine della lista. Parola non trovata.")
```

```
except FileNotFoundError:  
    print("[-] Errore: File wordlist non trovato.")
```

Risoluzione del Testo in Chiaro e Verifica Accesso

La password in chiaro corrispondente all'hash MD5 8d3533d75ae2c3966d7e0d4fcc69216b (associata all'utente 1337 nel database di default di DVWA) è:

charlie

Domande di Riflessione

Qual è il rischio che le piattaforme utilizzino il linguaggio SQL?

I siti web sono comunemente basati su database e utilizzano il linguaggio SQL. La gravità di un attacco di SQL injection dipende dall'aggressore.

Il rischio intrinseco nell'adozione di SQL non risiede nel linguaggio in sé, ma nella **gestione errata dell'input dell'utente**: se i dati inseriti dall'esterno vengono concatenati direttamente nelle query anziché essere trattati come semplici parametri, il database non distingue più il codice dai dati, aprendo la porta alla **SQL Injection (SQLi)**.

La gravità delle conseguenze dipende direttamente dalle intenzioni e dalle competenze dell'aggressore, oltre che dai permessi assegnati all'utente del database.

Naviga in internet ed esegui una ricerca per “prevenire attacchi di SQL injection”. Quali sono 2 metodi o passaggi che possono essere adottati per prevenire gli attacchi di SQL injection?

Le risposte varieranno, ma dovrebbero includere: filtrare l'input dell'utente, implementare un firewall per applicazioni web, disabilitare funzionalità/capacità non necessarie del database, monitorare le istruzioni SQL, utilizzare parametri con stored procedure e utilizzare parametri con SQL dinamico.

Utilizzo di query parametrizzate (con Prepared Statements o Stored Procedure): È la difesa primaria e più efficace. Consiste nel separare nettamente il codice SQL dai dati forniti dall'utente. Il database compila prima la struttura della query e tratta successivamente qualsiasi input esterno solo ed esclusivamente come un valore letterale (stringa, intero, ecc.), impedendo che caratteri speciali (come apici o operatori logici) possano alterare la logica del comando.

Implementazione di un Web Application Firewall (WAF): Agisce come filtro perimetrale a livello applicativo (Layer 7) tra i client e il web server. Il WAF analizza in tempo reale il traffico HTTP in ingresso alla ricerca di pattern noti, payload dannosi e firme tipiche di SQLi (come sequenze ' OR 1=1, tentativi di commento #, comandi UNION SELECT), bloccando le richieste prima che raggiungano il server e il database.

Filtraggio, convalida e sanificazione dell'input: Applicare elenchi di valori consentiti (*allowlist*), controlli di tipo e formattazione rigorosa prima dell'elaborazione dei dati.

Disabilitazione delle funzionalità non necessarie e minimo privilegio: Rimuovere o bloccare stored procedure estese rischiose (es. `xp_cmdshell` o funzioni per leggere/scrivere file su disco) e limitare i permessi dell'utente del database strettamente a quelli operativi necessari.

Monitoraggio e logging delle istruzioni SQL: Impiegare sistemi di audit del database (Database Activity Monitoring - DAM) per individuare query anomale, picchi di errori SQL o estrazioni massive di dati.